PQC DAILY STUDY SERIES

Assinaturas Baseadas em Hash Stateful vs. Stateless: Entendendo o SLH-DSA

Day 52 | Category: Conceitos Fundamentais de PQC Date: 2026-11-07 | DAILY MONITORING

Assinaturas Baseadas em Hash Stateful vs. Stateless: Um Mergulho Profundo no SLH-DSA (SPHINCS+)

Esquemas de assinatura baseados em hash são uma categoria importante de algoritmos pós-quânticos, conhecidos por suas fortes provas de segurança baseadas nas propriedades das funções de hash criptográficas. No entanto, eles existem em duas variações principais: stateful (com estado) e stateless (sem estado). Entender a diferença é crítico para sua implementação correta e segura. Hoje, exploramos essa distinção e por que a abordagem stateless do SLH-DSA (FIPS 205) é crucial para os protocolos modernos da internet.

O que são Assinaturas Baseadas em Hash Stateful?

Esquemas stateful, como o Leighton-Micali Signatures (LMS) e o eXtended Merkle Signature Scheme (XMSS), exigem que o assinante mantenha um estado. Esse estado é tipicamente um contador ou índice que rastreia qual chave privada de uso único (one-time key) foi utilizada. O princípio fundamental é que **cada chave de uso único deve ser usada apenas uma vez.**

- **Como funciona:** Um grande número de chaves de uso único é gerado, e suas chaves públicas correspondentes são combinadas em uma estrutura de árvore de Merkle para criar uma única chave pública de nível superior. Cada assinatura é gerada com uma chave de uso único diferente.
- **A Falha Crítica:** Se o estado não for perfeitamente gerenciado (ex: devido a rollbacks de VMs, operações de assinatura concorrentes ou bugs) e uma chave de uso único for reutilizada, um atacante pode forjar assinaturas. Essa regra de "uso único" é uma armadilha perigosa e implacável.

> **O Perigo da Má Gestão de Estado**
>
> Reutilizar uma chave privada em um esquema de assinatura baseado em hash stateful é uma falha catastrófica. Isso permite que um atacante deduza a chave privada e forje assinaturas à vontade. Isso os torna inadequados para muitos ambientes modernos,

> distribuídos e de alta concorrência, onde manter um estado perfeito e sincronizado é um grande desafio.

A Revolução Stateless: SLH-DSA (SPHINCS+)

O SLH-DSA (padronizado pelo NIST no FIPS 205 e também conhecido como SPHINCS+) é um esquema de assinatura baseado em hash **stateless** (sem estado). Ele resolve elegantemente o problema de gerenciamento de estado ao remover a necessidade de o assinante rastrear quais chaves foram usadas.

- **Como funciona:** Em vez de depender de um contador sequencial, o SLH-DSA usa um processo pseudoaleatório para selecionar a chave de uso único para each assinatura. A seleção é determinada pela mensagem que está sendo assinada e por um randomizador. Isso significa que, para uma dada mensagem, o processo de assinatura é determinístico, mas mensagens diferentes usarão partes diferentes da estrutura de chaves.
- **A Vantagem Chave:** O assinante não precisa mais manter um estado persistente entre múltiplas operações de assinatura. Cada assinatura é autocontida. Isso torna o SLH-DSA muito mais robusto e adequado para implantação no mundo real em sistemas complexos.

Comparativo: Stateful vs. Stateless

Métrica	Stateful (LMS, XMSS)	Stateless (SLH-DSA/SPHINCS+)
Gerenciamento de Estado	Requerido e crítico para a segurança. A reutilização de chave leva a uma falha catastrófica.	Não requerido. Cada assinatura é independente.
Tamanho da Assinatura	Geralmente menor (ex: ~2,5 KB para XMSS).	Significativamente maior (ex: ~8 KB para SLH-DSA-SHAKE-128f).
Velocidade de Assinatura	Mais rápido, pois envolve menos cálculos de hash por assinatura.	Mais lento, pois requer a geração de uma estrutura mais complexa para cada assinatura.
Robustez e Segurança	Frágil. Propenso a erros de implementação relacionados ao estado.	Altamente robusto. Resiliente a rollbacks de VMs e problemas de concorrência.
Aplicabilidade	Ideal para ambientes controlados (ex: CAs de assinatura de código, assinatura de firmware).	Ideal para uso geral em protocolos da internet (TLS, SSH, DNSSEC) и assinatura de software.

Aplicabilidade para a Segurança da Internet

A robustez de esquemas stateless como o SLH-DSA os torna a escolha clara para proteger os protocolos da internet. Imagine um servidor web ocupado com múltiplos threads ou processos tratando handshakes TLS. Tentar sincronizar um contador stateful entre todos eles sem nunca cometer um erro é quase impossível e um risco de segurança enorme.

O SLH-DSA, apesar de seu maior tamanho de assinatura e menor performance, fornece a garantia de segurança que é inegociável para a infraestrutura em escala de internet. Sua inclusão nos padrões PQC do NIST garante que os desenvolvedores tenham um algoritmo de assinatura digital quântico-resistente que pode ser implantado com confiança, sem o medo de vulnerabilidades relacionadas ao estado.

Autoavaliação Diária

1. Qual é o principal risco de segurança associado a assinaturas baseadas em hash stateful como o XMSS?
2. Como o SLH-DSA (SPHINCS+) resolve o problema de gerenciamento de estado?
3. Por que um esquema de assinatura stateless é geralmente preferido para aplicações de alta concorrência, como um servidor web tratando conexões TLS?
